POUR ALLER PLUS LOIN

- Tout système traitant des données sensibles[34] doit être mis en œuvre dans un **environnement dédié** (isolé logiquement).
- **Les opérations d'administration des serveurs devraient se faire via un réseau dédié et isolé**, accessible après une authentification robuste (voir la fiche n°5 - Gérer les habilitations) permettant une traçabilité renforcée (voir la fiche n°16 - Tracer les opérations).
- En plus des flux extérieurs, **les flux internes devraient être chiffrés** autant que possible (ex. : à l'aide des protocoles TLS, IPsec ou SSH).
- Isoler les serveurs obsolètes mais essentiels et limiter le traitement de données personnelles dessus dans l'attente de leur remplacement par un système à jour.
- S'agissant des logiciels s'exécutant sur des serveurs, il est conseillé d'utiliser des **outils de détection des vulnérabilités** (logiciels de scans de vulnérabilités tels que nmap[36], nessus[37] ou nikto[38]) ou audits pour les traitements les plus critiques afin de détecter d'éventuelles failles de sécurité. Des systèmes de détection et prévention des attaques sur des systèmes ou serveurs critiques peuvent aussi être utilisés.
- Restreindre les accès physiques et interdire les accès logiques à distance aux ports de diagnostic et de configuration.
- La version 1.3 de TLS est à privilégier ou, à défaut, la version 1.2 en respectant les recommandations publiées par l'ANSSI sur le sujet[39].
- **L'ANSSI a publié diverses recommandations**[40] parmi lesquelles la sécurisation de l'administration des systèmes d'information[41] et la mise en place de cloisonnement système[42].

35 Les données sensibles sont décrites à l'article 6 de la loi Informatique et Libertés et à l'article 9 du RGPD.

36 « Nmap », nmap.org

37 « Tenable Nessus », tenable.com

38 « Nikto2 », cirt.net

39 « Recommandations de sécurité relatives à TLS », cyber.gouv.fr

40 « Publications de l'ANSSI », cyber.gouv.fr

41 « Recommandations relatives à l'administration sécurisée des SI », cyber.gouv.fr

42 « Recommandations pour la mise en place de cloisonnement système », cyber.gouv.fr